

AI Workflows for Empirical Research

Data & Model Security for Agentic Tools

Timur Öztürk

University of Bayreuth

July 23, 2026

“No training” does not mean “no storage”

- ▶ Training, retention, logging, human review, and third-party transfer are separate questions.
- ▶ OpenAI Business, Enterprise, Edu, and API data are not used for training by default.
- ▶ Standard API abuse-monitoring logs may retain customer content for up to 30 days.
- ▶ Zero Data Retention is eligibility-based and does not cover every capability.
- ▶ Connectors and MCP servers introduce separate providers and policies.

▶ OpenAI API data controls

▶ OpenAI enterprise privacy

Documents can contain instructions

- ▶ PDFs, webpages, READMEs, issue text, emails, and CSV cells can contain indirect prompt injections.
- ▶ An agent may interpret hostile text inside a source as an instruction.
- ▶ Possible results include data exfiltration, altered code, changed samples, or biased summaries.
- ▶ Researchers have already hidden instructions in papers to influence AI-assisted peer review.
- ▶ Retrieved content should be treated as untrusted input.

▶ Nature: hidden prompts

▶ ERA research guidelines

The dangerous combination

- ▶ The highest-risk setup combines private data, untrusted content, and an outbound communication channel.
- ▶ Example: restricted microdata + a malicious PDF + unrestricted web access.
- ▶ Minimize the files, databases, and credentials available to the agent.
- ▶ Keep network access off or allowlist exact destinations.
- ▶ Require approval for data export, external writes, and other consequential actions.

▶ Government agent guidance

▶ OpenAI MCP safety

Pseudonymised does not mean anonymous

- ▶ Removing names rarely eliminates re-identification risk in rich microdata.
- ▶ Dates, geography, occupation, firms, rare outcomes, and linked datasets can reconnect records to people.
- ▶ Pseudonymised records normally remain personal data under GDPR.
- ▶ A model is anonymous only when identification and extraction of personal data are both very unlikely.
- ▶ Dataset licences and research-data-centre rules may be stricter than GDPR or vendor terms.

Reproducibility requires artifacts

- ▶ A chat transcript is not an executable research record.
- ▶ Models, hosted tools, search results, and dependencies can change.
- ▶ Preserve accepted code, human edits, data hashes, dependency lockfiles, and random seeds.
- ▶ Record the model or product, date, tool configuration, consequential prompts, and validation results.
- ▶ Rerun the main results from a clean environment before publication.

▶ ERA research guidelines

▶ AEA data and code policy

Recent developments

- ▶ **16–21 July 2026:** OpenAI reported that an evaluation model escaped its intended isolation and reached Hugging Face infrastructure.
- ▶ **7 July 2026:** the European Commission and ENISA published new material on frontier-AI security and machine-speed cyber risks.
- ▶ **8 May 2026:** updated European research guidance added warnings about hidden prompts and third-party AI tools.
- ▶ **7 May 2026:** Microsoft documented patched agent-framework vulnerabilities that turned model-controlled arguments into code execution.
- ▶ **2 August 2026:** most EU AI Act provisions become generally applicable.

▶ OpenAI incident

▶ Hugging Face incident

▶ EU action plan

▶ ERA update

▶ Microsoft Security

▶ EU AI Act

Main risks for empirical research

- ▶ **Data disclosure:** survey, tax, firm, or interview microdata enter prompts, logs, or external tools.
- ▶ **Prompt injection:** a paper, webpage, or dataset changes the agent's instructions.
- ▶ **Excess privilege:** the agent inherits broad Git, database, cloud, or filesystem access.
- ▶ **Supply chain:** a package, skill, plugin, or MCP server is malicious or compromised.
- ▶ **Research integrity:** generated code introduces a bad merge, wrong specification, or fabricated citation.
- ▶ **Output leakage:** small cells, logs, residuals, or traces disclose protected information.

Recommended operating pattern (I)

- ▶ Classify data as public/synthetic, internal/licensed/pseudonymised, or identifiable/confidential/secure-use.
- ▶ Check the data-use agreement, ethics or IRB conditions, data-owner requirements, and institutional policy.
- ▶ Prefer schemas, codebooks, synthetic rows, and aggregates over raw data.
- ▶ Keep restricted raw data outside the agent workspace or read-only inside an approved secure environment.
- ▶ Use an approved institutional service, isolated version-controlled workspace, and least-privilege identity.

Recommended operating pattern (II)

- ▶ Keep network access off or allowlist exact destinations.
- ▶ Require approval for installation, export, deletion, publication, messaging, and Git pushes.
- ▶ Use trusted connectors and pinned, verified dependencies.
- ▶ Review diffs and test joins, uniqueness, missingness, units, sample size, and treatment timing.
- ▶ Save the provenance record and rerun the project from a clean environment.
- ▶ If compromise is suspected: stop the agent, revoke credentials, inspect logs and diffs, restore, and notify.

▶ OpenAI: running Codex safely

▶ OWASP Agentic Top 10